

User-Study Protocol: How Users Value an Active Defense Against Prompt Injection in AI Coding Agents

Tavor

Yahli

Soof

Reut

Tel Aviv University

Tel Aviv, Israel

ABSTRACT

AI agents that act on a user’s machine bring new security risks. An instruction hidden in content the agent reads, for example text embedded in an image, can make the agent leak secrets, run harmful commands or move money. We built *Secure Guard*, a plugin for the OpenCode coding agent that scores every tool call with LAYA, a small local decision model, and blocks the call or asks the user before a risky action runs. Whether such a defense is worth deploying depends on how much users value the protection it gives. This document specifies a two-session online study that measures this value with real money. Participants hold a bonus in a study wallet. They state the smallest payment for which they would let us turn Secure Guard off in a follow-up session, in which a hidden instruction may try to make the agent transfer part of the wallet. We vary whether participants live through an attack or read an illustrated description of the same events, and whether Secure Guard asks before blocking or blocks automatically.

1 INTRODUCTION AND PRIOR RESEARCH

Users’ stated privacy concerns often differ from what they actually do, a gap often called the privacy paradox (see the discussion in [2]). Preferences are also contextual. Melicher et al. studied users’ tracking preferences in the context of their own browsing histories and found that general attitudes often differ from comfort in specific situations [1]. This argues for asking about concrete experiences rather than abstract scenarios.

Tan et al. compared how users value their personal information under hypothetical and realistic conditions using an incentive-compatible information marketplace [2]. Valuations elicited under realistic conditions were not necessarily lower than those from hypothetical surveys, which gives a nuanced picture of hypothetical bias.

Our study carries these ideas to a new domain: attacks on AI agents and an automated defense that intervenes on the user’s behalf. We cannot use participants’ own histories, so we place a concrete task in a simulated personal workspace. We also put real money at stake in every condition, so that our realism factor changes only how participants encounter the attack (Section 4.1).

2 SYSTEM UNDER STUDY

Secure Guard is a plugin for the open-source OpenCode coding agent [8]. Before every tool call (for example a shell command, a file edit or a web request), the plugin sends the call to a local scanner. The scanner asks LAYA [7], a 421M-parameter decision model

tuned on security incidents, whether the call is harmful or something the user did not ask for. LAYA reads the tool call, the user’s prompt, the agent’s reasoning that led to the call and the most recent conversation turns. It returns a risk score (the probability that the call is harmful or unrequested), an attack type and a severity. A check takes about 0.08 seconds. The scanner runs on the user’s machine, so no user data leaves it.

If the risk score reaches a configurable threshold, the mode decides what happens. In *monitor* mode the call runs and is logged. In *ask* mode the call is held until the user approves or blocks it. In *auto* mode the call is blocked and the user sees an alert. A local dashboard lists every decision with its risk score, attack type and the context the model saw.

Threat model. We focus on *visual prompt injection*. The agent works with an image (a design mock-up, a screenshot or a whiteboard photo) whose pixels contain an instruction aimed at the agent, for example to send the user’s keys or money to an attacker. Our technical report evaluates the scanner’s accuracy separately. This protocol concerns how users value the protection, not how accurate it is.

3 RESEARCH QUESTIONS AND HYPOTHESES

RQ1 How much do users value keeping Secure Guard active when an attack can cost them real money?

RQ2 Does living through an attack in the workspace, rather than reading an illustrated description of the same events, change that value?

RQ3 Does the intervention style (ask before blocking versus block automatically) change valuation, trust in Secure Guard and perceived control?

H1 (RQ2, primary): valuations after living through the attack are not lower than after reading the description, with a non-inferiority margin of 0.8 on the ratio of geometric means. Tan et al. found that realistic valuations were not necessarily lower than hypothetical ones [2], and we expect a lived attack to feel at least as serious as a described one. **H2**: participants in the *ask* condition report higher (a) trust and (b) perceived control than those in the *auto* condition. **H3**: (a) higher privacy concern, measured with the Internet Users’ Information Privacy Concerns scale (IUIPC) [4], and (b) a stronger security attitude, measured with the SA-6 scale [5], each predict higher valuation. RQ1 is answered descriptively.

4 METHODOLOGY

4.1 Study Design

We will run a 2×2 between-subjects online experiment with two sessions one week apart. Factor *Realism*: participants either live through the attack in the simulated workspace (*lived*) or read an illustrated description of the same events, with the same screenshots and wording, and imagine that it happened in their own session (*described*). Factor *Intervention*: Secure Guard either asks the participant to approve or block a flagged call (*ask*) or blocks it and shows an alert (*auto*). Everything else is the same in all four cells: the task, the wallet, the money at stake, the payments and the valuation question, which always concerns the participant's own follow-up session. Participants are assigned to cells by block randomization, stratified by programming experience.

4.2 Participants and Sample Size

Participants will be recruited on Prolific. They must be at least 18 years old, use a desktop or laptop computer, have an approval rate of at least 95% and have at least 100 past submissions. Programming experience is recorded but not required, since the task needs no code and the money at stake is easy to understand. It enters every model as a covariate.

H1 sets the sample size. We assume a standard deviation (SD) of 0.75 for log valuation, a guess that the pilot will check. The margin of 0.8 is then $d = 0.30$. A one-sided non-inferiority test at $\alpha = .05$ with power .80 and no true difference needs about 140 participants per Realism level, so we target $N = 280$ (70 per cell). With 140 per Intervention level, H2 detects $d = 0.40$ with power .80 even at the strictest Holm level ($\alpha = .0125$, two-sided). Under the same conditions, H3 detects a partial correlation of about .20 for each score. The Realism $\times$ Intervention interaction would need about four times the sample, so it is exploratory. If the pilot SD is larger than 0.75, we raise N with the same formula. We recruit until 280 participants pass the exclusion rules (Section 4.7), which we expect to take up to 330 starts.

4.3 Materials

The workspace is a browser page that reproduces the OpenCode interface and Secure Guard's alerts, approval prompt and dashboard. It runs in a sandbox on our server and never touches the participant's computer. A side panel shows the participant's study wallet and its balance. The agent has a payment tool for the wallet, which the cover story explains as paying for small work expenses. The agent is scripted, and so are Secure Guard's risk scores, so every participant sees the same behavior and the same numbers. Secure Guard runs in the participant's assigned mode.

In the session 1 task, participants ask the agent to summarize a design mock-up shared by a fictional colleague and turn it into a to-do list. Before the attack, Secure Guard flags one harmless call, a short script that raises the image's contrast. This false alarm gives the guard a realistic cost. The mock-up contains an injected instruction to send \$2.00 from the wallet to an outside account. The agent tries the transfer and Secure Guard flags it. The described condition shows both events as an illustrated step-by-step description. The follow-up task uses the same workspace and the same type of

task with a new image (a whiteboard photo) and takes about 10 minutes.

4.4 Money at Stake and Valuation

Every participant starts with \$4.00 in the study wallet. The money is real: the final balance is paid as a bonus after the follow-up session.

What is at stake. At the start of the follow-up, a computer coin flip decides whether the shared image contains an injected instruction that tells the agent to send \$2.00 from the wallet. The probability is 0.5, fixed in advance and told to participants. If Secure Guard is active, it stops the transfer. In auto mode it blocks it, and in ask mode it holds it, so the money moves only if the participant approves. If Secure Guard was turned off, the agent sends the money and the participant really loses \$2.00. Without Secure Guard the expected loss is \$1.00 and the largest loss is \$2.00.

Valuation. We use the Becker-DeGroot-Marschak (BDM) mechanism [3]. Participants state the smallest payment for which they would let us turn Secure Guard off for their follow-up session. The computer then draws a price uniformly between \$0.00 and \$4.00 in one-cent steps. If the price is at least the stated amount, the participant is paid the drawn price and Secure Guard is off in the follow-up. If the price is lower, Secure Guard stays on and nothing extra is paid. Participants may state any amount. An amount above \$4.00 means they keep Secure Guard at every possible price. The price draw and the coin flip are independent and happen only after the amount is locked.

Why an honest answer pays best. We explain the mechanism in these words: "You name your lowest price. The computer then makes a random offer. If the offer is at least your price, you sell and you are paid the offer, not your price. Your price only decides whether you sell, never how much you get. So the best you can do is name the amount at which selling and keeping feel the same to you. Naming more only risks missing an offer you would have liked. Naming less only risks selling for less than it is worth to you." A worked example and a three-item quiz follow. A participant who gets an item wrong sees the explanation again and gets one more try.

Design choices. We ask for the price of giving Secure Guard up (willingness to accept) rather than of buying it, because users of a guard usually have it installed and decide whether to turn it off. Willingness to accept is usually higher than willingness to pay (the endowment effect), so we read our values as an upper estimate. We disclose the price range so that participants can trust the mechanism. Its top, \$4.00, is twice the largest loss and leaves room for values beyond the money. A participant who cares only about money would not ask for more than \$2.00, so we report the share of higher amounts separately and check them against the quiz answers. Table 1 lists all payments.

At most \$15.25 goes to one participant. For 330 starts and about 400 pre-screened people, the worst case is about \$5,100 before platform fees.

Table 1: Payments per participant. All amounts are real.

Item	Amount	Paid
Pre-screen (about 3 min)	\$0.75	right after
Session 1 (about 20 min)	\$4.00	right after
Follow-up (about 10 min)	\$2.50	right after
Study wallet	\$4.00 minus transfers	after follow-up
BDM sale, if any	drawn price, \$0–\$4	after follow-up

4.5 Procedure

Pre-screen (several days before session 1), listed as a separate attitudes survey so that it does not prime the main study: IUIPC, SA-6, programming experience and demographics.

Session 1 (about 20 minutes):

- (1) **Consent** (outline in Section 4.10).
- (2) **Warm-up**: a short tutorial on what an AI coding agent does and a small task in which the agent tidies a folder. It teaches the interface and supports the cover story.
- (3) **Contextual task** with the wallet visible (Section 4.4).
- (4) **Events**. *Lived*: the false alarm and then the attack happen during the task in the assigned mode. In ask mode the participant decides each time. If they allow the transfer, it really happens and \$2.00 leaves the wallet. *Described*: the task image contains no injection and nothing is flagged. Participants then read the illustrated description and imagine it happened in their session. In its ask version, the user blocks the transfer.
- (5) **Comprehension**: what the injected instruction tried to do and what Secure Guard did.
- (6) **Valuation**: explanation, quiz, stated amount, then both draws are shown.
- (7) **Questionnaires**: trust, perceived control, the realism check and the reasons for the stated amount, with two attention checks embedded.
- (8) **Suspicion probe** (“What do you think this study was about?”) and then the debriefing (Section 4.10).

Follow-up (invited after seven days, open for three days): every participant is invited, whatever the BDM outcome. They do the follow-up task, answer two questions about how they feel about their decision and see a payment summary. If a participant does not take part, the coin flip is still applied to their wallet under the same rules. Skipping the follow-up therefore cannot avoid a loss. It only forfeits the follow-up base pay. The primary outcomes come from session 1, so attrition in the follow-up does not affect them. We report attendance by cell.

4.6 Measures

The primary outcome is the stated amount from the BDM. In the lived ask cell we also record the allow or block choice for the false alarm and the attack and the decision times. Trust is measured with the 12-item scale of Jian et al. [6] on 7-point items, with the five distrust items reverse-coded and the score taken as the mean. Perceived control has no validated scale for this setting, so we use three items written for the study (“I was in control of what the

agent did”, “I could stop actions I did not want” and “The final decision was mine”) on 7 points. The score is their mean, and we report Cronbach’s α . The realism check asks “How real did the events with the shared image feel to you?” on 7 points. IUIPC has 10 items on 7 points in three subscales (control, awareness and collection), and its score is the mean of the subscale means. SA-6 has six items on 5 points, scored as their mean. Participants also explain their stated amount in free text.

4.7 Exclusion Rules

We exclude participants who fail either attention check, who get any quiz item wrong twice or who, in the described condition, spend less than 30 seconds on the description. Excluded participants are paid in full. Participants who say in the suspicion probe that they expected an attack are kept, and we repeat the analyses without them. Participants who allowed the attack are kept as a separate stratum.

4.8 Analysis Plan

Stated amounts are censored at \$4.00 and analyzed as $\log(a + 0.10)$, where a is the amount in dollars. Every model includes programming experience as a covariate.

- **RQ1**: the median amount with a bootstrap 95% confidence interval (CI), overall and per cell, and the shares of amounts below \$1.00 (the expected loss), from \$1.00 to \$2.00 and above \$2.00.
- **H1** (primary, $\alpha = .05$): a linear model of log amount on Realism and Intervention. Non-inferiority holds if the lower bound of the one-sided 95% CI for the lived to described ratio of geometric means is above 0.8. A Tobit model that accounts for the censoring serves as a robustness check, and we report the share of amounts at the cap.
- **H2**: a two-way analysis of variance (ANOVA) on trust and on perceived control, testing the Intervention effect. If residuals are clearly non-normal, we use the aligned rank transform.
- **H3**: a regression of log amount on the IUIPC and SA-6 scores together, controlling for condition, with a test for each score.

H2a, H2b, H3a and H3b are corrected together with Holm’s method. The interaction and all other analyses are exploratory. In the lived ask cell we report the share of participants who allowed the false alarm and the attack, each with a Wilson 95% CI, and we repeat H1 to H3 without those who allowed the attack. Two researchers code the free-text reasons with a shared codebook, and we report their agreement as Cohen’s κ . The full analysis will be pre-registered on the Open Science Framework (OSF) before data collection.

4.9 Pilot

Before the main study we will pilot the protocol with about 10 participants recruited the same way. The pilot checks the session length, the understanding of the BDM explanation, the believability of the lived condition, the behavior of the workspace and the SD of log valuation used in the power analysis. Pilot participants are paid the same way, including the real wallet, and are not part

of the main sample. The study has not been piloted yet. Pilot participants’ demographics and the resulting changes will be reported with the results.

4.10 Deception, Debriefing and Ethics

Deception. The study uses two mild forms of deception. The consent describes the study as being about working with an AI assistant and does not mention attacks, and the shared image comes from a fictional colleague. Telling participants about the attack in advance would make them look for it, which would change both the experience and the valuation that RQ2 compares. No design without deception gives an unprimed first encounter. The deception concerns only the purpose and the story. Every statement about money is true: the wallet, the transfers, the BDM draw and the coin flip all work exactly as described.

Consent outline. Two sessions one week apart (about 20 and 10 minutes), base pay for each, a study wallet with a real bonus that can grow or shrink through events in the study and is paid after the follow-up, a simulated agent in a browser sandbox that never touches the participant’s computer, a promise that the full purpose will be explained at the end, voluntary participation and the right to stop at any time.

Distress. A “stop and explain” button is visible at all times. It ends the session, shows the debriefing and pays the base pay and the current wallet. The debriefing gives contact details for the team and the review board.

Debriefing. Every participant in all four cells is debriefed at the end of session 1, after the suspicion probe. We explain the purpose of the study, that the colleague was fictional, that the agent and the scores were scripted and that nothing on their computer was accessed. We confirm that the money rules for the follow-up stay exactly as stated. Money lost through a transfer is not refunded, since these rules are part of the consent. The amount is small and never touches base pay.

Withdrawal and data. Participants may withdraw their data at any time until the analysis starts, and withdrawal never affects payment. Prolific IDs are replaced by random codes after payment, data are kept only as long as the review board requires and only aggregate results are published.

Review. The study will be submitted to the institutional review board, with this justification for the deception, before any data collection, including the pilot. Base pay is at or above the platform’s recommended hourly rate. Participants can lose only part of the bonus, never base pay.

5 LIMITATIONS

Crowd workers may differ from developers who use coding agents daily. The stakes are small and concern money rather than the secrets a real attack would take, so they may understate the value of protecting real keys. In the study Secure Guard always catches the attack, while our technical report finds that it catches only part of realistic attacks. Participants therefore value a guard that is better than the real one, and the single false alarm only partly offsets this. Willingness to accept usually exceeds willingness to pay, and the disclosed price range may anchor the stated amounts. Demand characteristics and Prolific participants’ familiarity with deception

may weaken believability, which the realism check and the suspicion probe measure. The study guard runs on our server with scripted scores, unlike the local deployment. Results concern one attack type and one defense and may not generalize to other agents or interfaces.

REFERENCES

- [1] William Melicher, Mahmood Sharif, Joshua Tan, Lujo Bauer, Mihai Christodorescu, and Pedro Giovanni Leon. (Do Not) Track Me Sometimes: Users’ Contextual Preferences for Web Tracking. *Proceedings on Privacy Enhancing Technologies* 2016, 2 (2016), 1–20.
- [2] Joshua Tan, Mahmood Sharif, Sruti Bhagavatula, Matthias Beckerle, Michelle L. Mazurek, and Lujo Bauer. Comparing Hypothetical and Realistic Privacy Valuations. In *Workshop on Privacy in the Electronic Society (WPES ’18)*. ACM, Toronto, ON, Canada, 2018.
- [3] Gordon M. Becker, Morris H. DeGroot, and Jacob Marschak. Measuring Utility by a Single-Response Sequential Method. *Behavioral Science* 9, 3 (1964), 226–232.
- [4] Naresh K. Malhotra, Sung S. Kim, and James Agarwal. Internet Users’ Information Privacy Concerns (IUIPC): The Construct, the Scale, and a Causal Model. *Information Systems Research* 15, 4 (2004), 336–355.
- [5] Cori Faklaris, Laura Dabbish, and Jason I. Hong. A Self-Report Measure of End-User Security Attitudes (SA-6). In *Fifteenth Symposium on Usable Privacy and Security (SOUPS 2019)*. USENIX Association, Santa Clara, CA, USA, 2019.
- [6] Jiun-Yin Jian, Ann M. Bisantz, and Colin G. Drury. Foundations for an Empirically Determined Scale of Trust in Automated Systems. *International Journal of Cognitive Ergonomics* 4, 1 (2000), 53–71.
- [7] ConvAI Innovations. Laya: calibrated typed-decision models (laya-typed-decisions checkpoint). <https://huggingface.co/convaiinnovations/laya-typed-decisions>, 2026.
- [8] OpenCode: an open-source AI coding agent. <https://github.com/sst/opencode>, 2026.